

A thick, light gray L-shaped frame is positioned on the left and bottom edges of the image, framing the central text.

OPEN WEB APPLICATION SECURITY PROJECT

Open Web Application Security Project (OWASP)

Open Web Application Security Project (OWASP) — это открытый проект обеспечения безопасности веб-приложений.

Сообщество OWASP включает в себя корпорации, образовательные организации и частных лиц со всего мира. Сообщество работает над созданием статей, учебных пособий, документации, инструментов и технологий, находящихся в свободном доступе.

Фонд OWASP — это благотворительная организация, которая оказывает поддержку и осуществляет управление проектами и инфраструктурой OWASP. Кроме того, Фонд зарегистрирован как некоммерческая организация в Европе с июня 2011 года.

Open Web Application Security Project (OWASP)

OWASP не аффилирован ни с одной компанией, занимающейся разработкой технологий, но он поддерживает грамотное использование технологий безопасности. Проект избегает аффилирования, так как полагает, что свобода от влияния со стороны других организаций может облегчить распространение беспристрастной, полезной и дешевой информации о безопасности приложений.

Участники сообщества OWASP делают приложения безопаснее, учитывая человеческий фактор и технологический уровень.

Open Web Application Security Project (OWASP)

Наиболее востребованные документы, опубликованные OWASP, включают в себя: [Руководство OWASP](#), [Обзорное Руководство по Коду OWASP](#) и широко применяемый [Проект Топ-10 OWASP](#).

Самыми распространёнными инструментами [OWASP](#) являются [тренировочная среда](#), [прокси-анализатор](#) и [.NET инструменты](#). OWASP состоит примерно из 190 местных отделений, располагающихся по всему миру и тысяч участников в листах рассылки проекта.

Open Web Application Security Project (OWASP)

OWASP организовал серию конференций AppSec для дальнейшего построения сообщества, посвященного безопасности приложений.

OWASP создаёт стандарты, первый из которых был опубликован под названием OWASP Application Security Verification Standard (ASVS)). Основная цель OWASP ASVS — это стандартизация диапазона охвата и уровня строгости доступных на рынке приложений, обеспечивающих безопасность. Целью OWASP ASVS также являлось создание набора коммерчески успешных открытых стандартов, приспособленных для специализированных веб-технологий.

Open Web Application Security Project (OWASP)

Лидеры OWASP несут ответственность за принятие решений о техническом руководстве, приоритеты проекта, расписание и выпуск продукции.

В целом, лидеры OWASP могут восприниматься как менеджмент Фонда OWASP.

В OWASP официально работает 8 человек, вследствие чего у проекта крайне низкие расходы, покрываемые конференциями, корпоративными спонсорами и рекламой. OWASP ежегодно награждает грантами корпоративных и индивидуальных членов за разработку многообещающих приложений, обеспечивающих безопасность.

С 2011 года OWASP зарегистрирована как некоммерческая организация в Бельгии под именем OWASP Европа VZW.

Open Web Application Security Project (OWASP)

Для каждого пункта рейтинга риск посчитан экспертами на основе методики OWASP Risk Rating Methodology и включает оценку по следующим критериям: распространенности соответствующих уязвимостей в приложениях, сложности их обнаружения и эксплуатации, а также критичности последствий их эксплуатации. По понятным причинам в расчетах критичности рисков не учитываются бизнес-последствия от их реализации. Там, где это возможно, названия рисков в рейтинге соотносятся с названиями соответствующих уязвимостей в классификации CWE. Следует отметить, что в отличие от классификаций, проект OWASP Top 10 не претендует на охват всех имеющихся рисков, а лишь представляет самые актуальные из них на момент выпуска рейтинга.

Open Web Application Security Project (OWASP)

Первая версия рейтинга OWASP Top 10 появилась в 2004 году, и с тех пор документ обновляется каждые три-четыре года. Обновленные версии публиковались в 2007, 2010, 2013 и 2017 годах.

Open Web Application Security Project (OWASP)

Последняя версия рейтинга, опубликованная в 2017 году, содержит следующие риски:

- A1 – Внедрение кода (Injection).
- A2 – Некорректная аутентификация (Broken Authentication).
- A3 – Утечка чувствительных данных (Sensitive Data Exposure).
- A4 – Внедрение внешних XML-сущностей (XXE – XML External Entities).
- A5 – Нарушение контроля доступа (Broken Access Control).
- A6 – Небезопасная конфигурация (Security Misconfiguration).
- A7 – Межсайтовый скриптинг (XSS – Cross-Site Scripting).
- A8 – Небезопасная десериализация (Insecure Deserialization).
- A9 – Использование компонентов с известными уязвимостями (Using Components with Known Vulnerabilities).
- A10 – Отсутствие журналирования и мониторинга (Insufficient Logging & Monitoring).

Open Web Application Security Project (OWASP)

На схеме отражены отличия текущей версии от предыдущей:

OWASP Top 10 – 2013	→	OWASP Top 10 – 2017
A1 – Внедрение кода	→	A1 – Внедрение кода
A2 – Некорректная аутентификация и управление сессией	→	A2 – Некорректная аутентификация
A3 – Межсайтовый скриптинг	↘	A3 – Утечка чувствительных данных
A4 – Небезопасные прямые ссылки на объекты (объединено с A7)	U	A4 – Внедрение внешних XML-сущностей (новый)
A5 – Небезопасная конфигурация	↘	A5 – Нарушение контроля доступа (объединено)
A6 – Утечка чувствительных данных	↗	A6 – Небезопасная конфигурация
A7 – Отсутствие контроля доступа к функциональному уровню (объединено с A4)	U	A7 – Межсайтовый скриптинг
A8 – Подделка межсайтовых запросов	☒	A8 – Небезопасная десериализация (новый)
A9 – Использование компонентов с известными уязвимостями	→	A9 – Использование компонентов с известными уязвимостями
A10 – Непроверенные перенаправления и переходы	☒	A10 – Отсутствие журналирования и мониторинга (новый)

Open Web Application Security Project (OWASP)

Для каждого пункта в OWASP Top 10 представлена общая информация, описание, рекомендации по предотвращению, примеры соответствующих атак и полезные ссылки.

Рейтинг OWASP Top 10 составляется на основе данных, предоставляемых сообществом экспертов отрасли информационной безопасности. В 2017 году рейтинг был обновлен на основе данных, собранных из отчетов 23 компаний, специализирующихся в сфере безопасности веб-приложений, в которых было проанализировано свыше 114 тысяч веб-приложений. В предоставленных данных присутствовали результаты как автоматического, так и ручного анализа, однако автоматический преобладал. При этом данные по 68% от общего числа приложений были предоставлены компанией Veracode, занимающейся автоматическим анализом (статическим и динамическим).

Open Web Application Security Project (OWASP)

Для оценки рисков использовались две группы факторов: факторы, влияющие на возможности атакующего по обнаружению и эксплуатации уязвимостей, а также факторы, влияющие на критичность последствий эксплуатации уязвимостей. В первую группу входят распространенность, сложность обнаружения и простота эксплуатации. Ко второй группе относятся последствия эксплуатации уязвимости. Некоторые важные факторы, например, такие как последствия эксплуатации уязвимости для бизнеса, модели злоумышленников, технические особенности невозможно проанализировать для всех веб-приложений в целом без учета специфики конкретного веб-приложения, поэтому они не рассматривались. Вероятностные характеристики выявлялись на основе предоставленных данных, а возможные последствия оценивались сообществом экспертов. Каждый фактор для конкретной уязвимости получал оценку от 1 до 3, и для получения общей оценки риска среднее арифметическое первой группы факторов умножалось на среднее арифметическое второй группы факторов.

Open Web Application Security Project (OWASP)

В настоящее время упоминание OWASP Top 10 часто является скорее маркетинговым ходом, чем реальной гарантией качественной защиты веб-приложений. С другой стороны, этот рейтинг хорош для отсылок благодаря своей широкой известности, может использоваться как стартовая точка и для привлечения внимания к обеспечению безопасности веб-приложений.

С 2011 года OWASP выпускает рейтинг Top 10 Mobile Risks, который обновлялся в 2014 и 2016 годах. В него входят следующие риски:

- M1 – Обход ограничений безопасности платформы (Improper Platform Usage).
- M2 – Небезопасное хранение данных (Insecure Data Storage).
- M3 – Небезопасная передача данных (Insecure Communication).
- M4 – Небезопасная аутентификация (Insecure Authentication).
- M5 – Слабая криптостойкость (Insufficient Cryptography).
- M6 – Небезопасная авторизация (Insecure Authorization).
- M7 – Низкое качество кода в клиентской части приложения (Poor Code Quality).
- M8 – Модификация кода (Code Tampering).
- M9 – Анализ исходного кода (Reverse Engineering).
- M10 – Скрытый функционал (Extraneous Functionality).